Kerbo-S Change Document, Sprint 1

AI-Assisted Kerberos Security Auditor | CSCE 4907 Senior Capstone

GitHub URL: https://github.com/chancellorr/Cybersecurity-Capstone.git

Team: Chance Edwards, Ben Grider, David Pantoja, Jessica Yescas | Revision date: October 29, 2026

Purpose

Sprint 1 produced ten requirement changes, seven design changes, two implementation facts and five proposed process changes; the biggest are that severity is now computed from the risk score and that collection is separated from analysis by a snapshot. Each entry states what changed, why, and the impact. References point to Requirements Document v2.0 (C-xx) and Design Document v2.0 (D-xx).

1. Summary

Area	Changes	Headline
Requirements	10 (RC-01 to RC-10)	Contradictions fixed, rule sources defined, AI role and testing made measurable
Design	7 (DC-01 to DC-07)	Pipeline with typed hand-offs, snapshot boundary, AI Gateway, config-driven scoring
Implementation	2 (IC-01, IC-02)	MIT Kerberos lab built; no application code, repository or prototype yet
Process	5 (PC-01 to PC-05), proposed	Repository, Trello, ownership and cadence to recover the schedule

2. Requirement Changes

ID	What changed	Why	Impact	Ref
RC-01	Severity is computed from the weighted risk score; fixed per-rule severities were removed and baseline factor values defined for every rule.	v1.0 contradicted itself: KC-02 was High in the rule but Critical (76) in Table 7, and KC-07 scored 92 while its worked example gave 88.5.	A scorer and a factor config are required. KC-02 is now High (70.0). Tests check both score and severity.	C-01, FR-RSK-02, 03
RC-02	Rule definitions and sources corrected: policy data maps to KC-03,	Copy error in v1.0 Table 9,	Collectors must read the ACL file,	C-02 to C-05, C-

ID	What changed	Why	Impact	Ref
	08, 09; KC-06 reads `kadm5.acl` plus a justification file; KC-05, 10, 11 read the KDC log; KC-04 and KC-05 handle never-used accounts; KC-07 adds 3DES, `allow_weak_crypto` and principal keys.	missing data sources, and logic that would produce false positives.	justification file and KDC log. New lab fixtures are needed and log formats must be verified.	08
RC-03	KC-11 uses a configurable fixed threshold; learned baselines moved to Release 2.	The v1.0 baseline was never defined.	Simpler MVP; the default threshold must be calibrated on normal lab traffic.	C-07, FR-R2-05
RC-04	Platform limited to Linux (Ubuntu); Windows host support removed. Windows clients are still audited through KDC logs.	`kadmin.local` runs only where the MIT KDC runs, and the lab has no Windows KDC.	Narrower scope than v1.0 Table 1. Instructor confirmation is still pending.	C-06, Section 5.8
RC-05	Added requirements for snapshot export and import, evidence hashing, configurable thresholds and a headless command-line mode.	Allow development and testing without the VM, provide tamper evidence, and let thresholds be tuned.	Adds work to the collector and config modules but removes most test dependence on the VM.	C-09
RC-06	AI role defined as correlation, advisory remediation order, environment-specific remediation and audience translation. The AI cannot change scores. Added provider interface with mock mode, input sanitization and schema-validated output.	Instructor feedback items 3 and 9, and the threat model.	New AI Gateway component; prompts are versioned; AI features can be tested offline.	C-09, C-12 to C-14
RC-07	Validation scenarios grew from 8 to 15, with ground-truth manifests and formal TP, FP, FN and TN definitions. Added a measurable AI evaluation method.	Feedback items 4, 5 and 10. v1.0 had no test for KC-06, KC-09 or KC-11.	Fixtures and manifests must be built before the engine. An evaluation script is needed.	C-10, C-14, C-16
RC-08	Added threat-to-requirement	Feedback items	Small extra work for	C-16, C-

ID	What changed	Why	Impact	Ref
	traceability and a report integrity digest with a verify function. Completion measures were removed from the success criteria.	7 and 10.	the digest; security claims are now testable.	17
RC-09	MVP defined as all Must and R1 requirements with a cut order for Should items. The duplicate Multi-KDC entry was removed and Security Analyst renamed Security Auditor.	Feedback item 8 and consistency.	Clear scope control if the schedule slips.	C-11, C-18
RC-10	Data collection specified per source: commands, files, privileges and failure behavior.	Feedback item 6.	Establishes that collection needs sudo or root on the KDC host and read access to logs.	C-15

3. Design Changes

ID	What changed	Why	Impact	Ref
DC-01	Layers that called each other directly became a pipeline with typed hand-offs (Snapshot, Finding, AiOutput) and a persisted result at each stage.	Each stage must be testable alone and reproducible.	More data classes up front; far simpler tests.	D-01
DC-02	Collectors write hashed raw artifacts and a normalized Snapshot; the rule engine reads only the Snapshot.	Develop without the VM, reproducible audits, tamper evidence.	Two code paths (live and import) and extra disk use.	D-02
DC-03	The AI layer became an AI Gateway: sanitizer, pseudonymizer, versioned prompts, provider interface (OpenAI and mock) and schema validation.	Prompt injection and data exposure threats; offline testing.	Extra component; free-form AI answers are no longer accepted.	D-03
DC-04	Thresholds and risk-factor baselines moved to validated config; severity is derived.	Fixes the KC-02 contradiction and allows tuning.	A bad config could skew results, so it is validated on load.	D-04
DC-05	One GUI process became a headless core library with GUI and CLI front ends, a	The KDC VM has no desktop; the	Manual snapshot copy step; thread	D-05

ID	What changed	Why	Impact	Ref
	worker thread, and a split deployment (collect on the KDC, analyze on a workstation).	interface must stay responsive; the same code runs under test.	handling.	
DC-06	Report generation moved out of the AI layer into a Report Builder; tables come from the database and AI supplies text only.	Reports must work with the AI down and be verifiable.	Two sources feed each report.	D-06
DC-07	A defined SQLite schema with triggers that make findings immutable.	Meets FR-DB-02 and the result-manipulation threat.	Triggers need tests; a local admin can still replace the file.	D-07

4. Implementation Changes

ID	What changed	Why	Impact
IC-01	An MIT Kerberos KDC was established in an Ubuntu Server VM using VirtualBox.	It is the foundation for real data capture and test scenarios.	The team can capture real `kadmin.local` output and plant test misconfigurations. The server has no desktop, which drove the split deployment (DC-05).
IC-02	No Kerbo-S source code, GitHub repository or prototype existed at the end of Sprint 1, which is a variance from the Sprint 1 plan.	Development work was not distributed and tracked closely enough, as the Sprint 1 reflection notes.	Sprint 2 starts with recovery work in this order: repository and walking skeleton, lab fixtures, collectors and parsers, rule engine, scoring and database, GUI shell. AI integration and PDF reporting follow once the engine passes its tests.

5. Process Changes (Proposed)

The team confirms these at its next meeting; they are not yet in effect.

ID	What changes	Why	Impact
PC-01	Create the GitHub repository with the layout in Design Document Section 12; all work goes through branches and pull requests with one reviewer.	The instructor reviews code and commit history, and code outside the repository is penalized.	Visible history; small review overhead.
PC-02	Trello cards carry a requirement ID, an	The board must show	Status is

ID	What changes	Why	Impact
	owner and a due date; Done means merged and tested.	completed, ongoing and planned work accurately.	traceable to requirements.
PC-03	Each member owns one vertical slice: lab and collectors, audit engine, GUI, AI and reports.	Unclear ownership caused the Sprint 1 gap.	Everyone can demo and explain a working piece.
PC-04	Two short check-ins per week and a working demo each week.	Earlier detection of stalled work.	About two hours per week per member.
PC-05	AI-assisted output is checked against MIT Kerberos documentation and against fixtures captured from the lab, and AI use is recorded in each reflection.	The reflection already states AI output must be verified; this makes it a practice.	Slightly slower, but fewer technical errors.

6. Areas With No Significant Change

Area	Statement
Core technology	Python, PyQt6, SQLite, Git/GitHub and the MIT Kerberos lab are unchanged from the approved proposal.
Project scope	Desktop application, read-only auditing, no autonomous remediation: unchanged.
Rule set	Eleven rules (KC-01 to KC-11) in four categories: unchanged in number and purpose; details corrected as listed in RC-02.
Risk formula	Four weighted factors, weights of 40, 30, 20 and 10 percent, and the four score bands: unchanged.
Use cases	UC-01 to UC-10 unchanged; UC-06 gains sanitization as an internal step.
Test environment platform	MIT Kerberos on Ubuntu in VirtualBox: unchanged.

7. Impact on Sprint 2

- The first week is recovery work: repository, skeleton, fixtures. Feature work starts only after the skeleton runs.
- Sprint 2 scope is collectors, parsers, the rule engine with unit tests, scoring, the database and a first GUI window. AI and PDF reporting are Sprint 2 stretch work.
- Open items that could cause further change: the final log formats, the KC-11 threshold, the OpenAI model choice, and instructor approval of the Linux-only decision.